

VibeSecSys Security Report

Summary of Findings

The scan shows a **highly exposed environment** across 3 hosts, with **48 open ports** and a broad range of services enabled. Two hosts (**192.168.56.20** and **192.168.56.40**) expose many legacy and high-risk services, including:

- **Telnet (23)**
- **FTP (21, 2121)**
- **NetBIOS/SMB (139, 445)**
- **RPCBind/NFS (111, 2049)**
- **r-services (512, 513, 514)**
- **VNC (5900)**
- **X11 (6000)**
- **Java RMI (1099)**
- **AJP13 (8009)**
- **Databases (MySQL 3306, PostgreSQL 5432)**
- **Bindshell / shell services (1524, 514)**

The presence of **bind shells** and **exec/login/shell** services is especially concerning, as these are commonly associated with insecure lab systems, misconfigurations, or compromised hosts.

Host **192.168.56.30** is comparatively minimal, with only **SSH and HTTP** open, which is a much smaller attack surface than the other two systems.

Risks Identified

1. Exposure of insecure legacy protocols

Services such as **Telnet, FTP, rsh/rlogin/rexec, and X11** transmit data poorly or without strong protection, making them vulnerable to:

- Credential interception
- Session hijacking
- Unauthorized remote access
- Plaintext data leakage

2. Multiple remote administration surfaces

The environment exposes many management and remote execution services:

- SSH
- Telnet
- VNC
- X11
- RPC services

- Java RMI
- AJP13

This significantly increases the chance of:

- Brute-force attacks
- Remote exploitation
- Misuse of administrative interfaces

3. File-sharing and network service exposure

SMB/NetBIOS, NFS, RPCBind are common targets for enumeration and lateral movement. Risks include:

- Unauthorized file access
- Weak share permissions
- Remote code execution via vulnerable components
- Internal trust abuse

4. Database exposure

Open **MySQL** and **PostgreSQL** ports suggest direct database access is possible from the network. Risks:

- Weak or default credentials
- Unauthorized querying or modification of data
- Service enumeration and exploitation
- Credential dumping if access controls are weak

5. Potential compromise indicators

Services labeled **bindshell**, **shell**, and **exec** are red flags. These are not normal production exposures and may indicate:

- Deliberate lab/vulnerable system design
- Severe misconfiguration
- A compromised host or backdoor-like access surface

6. Web application and Java middleware risk

Open **HTTP (80, 8180)** and **AJP13 (8009)** suggest web application components, possibly Apache/Tomcat-related. Risks:

- Web app vulnerabilities
- Tomcat/AJP exposure
- File inclusion, traversal, or RCE depending on versions/configuration

7. Attack surface concentration

Hosts **192.168.56.20** and **192.168.56.40** have nearly identical, large service sets, which indicates:

- Weak segmentation
- Overexposed services

- Possibly cloned or intentionally vulnerable environments
-

Misconfigurations

1. Unnecessary services enabled

There are many services that should not typically be exposed together on a single host:

- Telnet
- FTP
- r-services
- IRC
- VNC
- X11
- Java RMI
- AJP13
- NFS

This suggests poor service hardening or lab-like default configurations left in place.

2. Plaintext remote access protocols

Telnet and **FTP** are major misconfigurations in most environments because they do not provide secure transport.

3. Insecure remote execution services

Ports **512/513/514** and **1524** indicate risky remote command execution or shell access, which should not be available in secure production systems.

4. Broad database exposure

3306 and **5432** appear open externally or at least network-wide, which is often unnecessary and unsafe.

5. Overexposed middleware

AJP13 (8009) should generally be restricted to internal use only. Exposing it broadly is a common mistake.

6. Weak network segmentation

The same service stack on multiple hosts suggests that segmentation, firewalling, or host-based access controls are insufficient.

7. Possible backdoor or intentionally vulnerable services

The presence of **bindshell** is not standard and should be treated as a critical misconfiguration until proven otherwise.

Recommendations

Priority 1: Immediate containment

1. **Restrict or disable Telnet, FTP, r-services, X11, IRC, and VNC** unless explicitly required.
2. **Investigate bindshell, exec, login, and shell services immediately** to confirm whether these are intentional or unauthorized.
3. **Limit MySQL, PostgreSQL, NFS, SMB, and AJP13 to trusted internal hosts only** using firewall rules and ACLs.
4. **Segment 192.168.56.20 and 192.168.56.40** from broader network access if this is not a lab environment.

Priority 2: Secure remote administration

1. Replace **Telnet with SSH**.
2. Replace **FTP with SFTP or FTPS**.
3. Disable legacy **r-services** and use SSH-based administration.
4. Restrict **VNC** and **X11** to VPN or jump-host access, with strong authentication.

Priority 3: Harden exposed services

1. Ensure **SSH** uses:
 - Key-based authentication
 - MFA where possible
 - Root login disabled
 - Strong ciphers and MACs
2. Harden **HTTP/8180** services:
 - Patch web servers and frameworks
 - Remove default apps and sample content
 - Review for exposed admin interfaces
3. Review **AJP13** configuration:
 - Bind to localhost or internal interface only
 - Disable if unused
4. Secure **database services**:
 - Restrict to application hosts
 - Remove default accounts
 - Enforce strong authentication and least privilege
5. Secure **NFS/SMB**:
 - Limit exports/shares
 - Disable guest/anonymous access
 - Use host-based allowlists

Priority 4: Monitoring and validation

1. Run a **full vulnerability assessment** on the exposed hosts.
2. Confirm whether the services are part of a **deliberate vulnerable lab** or production system.
3. Check for:
 - Default credentials
 - Outdated software versions
 - Anonymous access

- Misconfigured permissions
- 4. Review host logs and EDR/AV telemetry for signs of misuse or compromise.

Priority 5: Long-term control improvements

1. Implement **network segmentation** and firewall baselines.
 2. Maintain a **service inventory** and remove unauthorized listeners.
 3. Use **secure configuration baselines** for Linux/Unix services.
 4. Add **continuous port and asset monitoring** to detect unexpected exposures.
 5. Apply regular **patch management** and configuration compliance checks.
-

Overall assessment

- **Risk level: High**
- The environment contains many **legacy, insecure, and potentially dangerous services**.
- The combination of **plaintext services, remote shells, database exposure, and bindshell indicators** suggests serious hardening gaps or a purposely vulnerable environment.
- Immediate review is recommended, especially for **192.168.56.20** and **192.168.56.40**.

If you want, I can also convert this into a **formal vulnerability report format** with severity ratings and an executive summary.